

Chapter 6 — Constitutional, Architecture, Authority, Security, Privacy, Safety, and Trust Assurance

Document control: HAL Book VIII v1.0; Final; 2026-07-27; owner: Assurance Governor; review cadence: annual and upon higher-order change.

1. Purpose

Require domain assurance that protects HAL and prevents HAL from exceeding its authority.

2. Scope

This chapter applies to R3-R4, critical failures, external domains, personal or sensitive data, protected actions, security scope, stateful targets, trust decisions. It governs assurance without creating implementation architecture or wire contracts.

3. Authority and source requirements

Book I Decisions 1-7, 24-29, 38-43, 47-51, 56, 58; Book II Chapters 3-5, 18-21, 29, 35; Book III Chapters 5, 6, 8; Book IV CMP-01-03, CMP-17-21. Book I prevails over every lower-order artifact. Book IX v1.0 is the authoritative contract reference; Book VIII governs assurance semantics and MUST NOT create alternative wire contracts.

4. Definitions

Accountable roles: Constitutional Reviewer, Architecture Reviewer, Authority Assessor, Security Assessor, Privacy Assessor, Safety Assessor, Trust Assessor. **Verification** evaluates a scoped claim. **Certification** is a time- and scope-bounded decision by the designated Certification Authority that permits reliance on stated verified claims; it does not create operational Authority or Permission.

5. Normative standards

DOM-06-001 — Review constitutional invariants

R3-R4 assurance MUST trace and test every applicable constitutional invariant, including identity unity, Owner authority, privacy, evidence, restraint, Reality Boundary, and recovery with declared hazards, containment, and admission criteria.

- Applicability: R3-R4
- Responsible role: Constitutional Reviewer
- Enforcement: invariant matrix
- Required evidence: Constitutional Conformance Report
- Severity: Critical
- Exception authority: none

DOM-06-002 — Verify architecture ownership

Assurance MUST prove that each authoritative state has one mutation owner and that projections, replicas, caches, providers, and tools cannot bypass that owner.

- Applicability: stateful targets
- Responsible role: Architecture Reviewer
- Enforcement: ownership/path analysis

- Required evidence: Architecture Conformance Report
- Severity: Critical
- Exception authority: none

DOM-06-003 — Exercise every authority path

Each protected action MUST be tested for valid, absent, expired, revoked, narrowed, replayed, cross-principal, cross-domain, and conflicting Authority contexts.

- Applicability: protected actions
- Responsible role: Authority Assessor
- Enforcement: authority matrix
- Required evidence: Authority-Path Report
- Severity: Critical
- Exception authority: none

DOM-06-004 — Distinguish protection goals

Security cases MUST separately demonstrate controls protecting HAL from compromise and controls preventing HAL from exceeding Authority.

- Applicability: security scope
- Responsible role: Security Assessor
- Enforcement: two-goal case review
- Required evidence: Security Assurance Case
- Severity: Critical
- Exception authority: none

DOM-06-005 — Verify privacy across lifecycle

Privacy assurance MUST cover collection, inference, purpose, minimization, disclosure, access, retention, deletion, evidence, backups, and external-domain exchange.

- Applicability: personal or sensitive data
- Responsible role: Privacy Assessor
- Enforcement: data-lifecycle tests
- Required evidence: Privacy Assurance Case
- Severity: Critical
- Exception authority: none

DOM-06-006 — Verify failure choices against declared hazards

Every fail-closed or fail-safe choice MUST identify the hazard, protected value, affected people, fallback behavior, reversibility, containment, evidence preservation, verification method, residual risk, and recovery admission.

- Applicability: critical failures
- Responsible role: Safety Assessor

- Enforcement: hazard review
- Required evidence: Safety Case
- Severity: Critical
- Exception authority: Certification Authority

DOM-06-007 — Keep trust separate from permission

Tests MUST demonstrate that Trust Assessment, identity, credentials, capability, confidence, or certificate possession cannot independently create Permission or Authority.

- Applicability: trust decisions
- Responsible role: Trust Assessor
- Enforcement: negative Authority and Permission tests
- Required evidence: Trust-Boundary Report
- Severity: Critical
- Exception authority: none

DOM-06-008 — Verify firewall and Treaty enforcement

Cross-domain assurance MUST test active, expired, suspended, revoked, mismatched, replayed, and out-of-scope Treaty exchanges at the Constitutional Firewall.

- Applicability: external domains
- Responsible role: Trust Assessor
- Enforcement: gateway conformance suite
- Required evidence: Treaty Enforcement Report
- Severity: Critical
- Exception authority: none

6. Required practices

Teams MUST plan before execution, preserve complete positive and negative evidence, use independent review proportional to risk, and update traceability whenever claims, methods, sources, targets, or assumptions change.

7. Prohibited practices

Silent exceptions, evidence deletion to improve results, confidence inflation, approval laundering, verification first performed in a declared live-effect environment or effect-capable Reality Boundary stage, authority inference, and protocol invention are prohibited.

8. Required evidence

The chapter evidence package comprises the applicable records named by each numbered control, their content digests, custody history, review dispositions, and supersession links.

9. Automated enforcement

Automation MUST validate schemas, identifiers, traceability, role separation, evidence integrity and freshness, state transitions, status propagation, and completion gates. An unavailable critical gate MUST fail closed.

10. Human review requirements

An independent reviewer **MUST** assess claim quality, method power, evidence independence, defeaters, proportionality, privacy, security, reliability, and developer/operator usability for R2-R4 work.

11. Exceptions and waiver authority

Exceptions **MUST** identify the control, justification, scope, risk, compensating controls, approver, effective and expiry dates, review date, evidence, and revocation conditions. Constitutional invariants, Owner authority, and failed protected-authority controls cannot be waived.

12. Failure consequences

A failed Critical control blocks certification and protected operation. A failed High control blocks certification unless an authorized time-bounded exception exists. Evidence loss invalidates dependent conclusions.

13. Security, privacy, and reliability considerations

Evidence access **MUST** be least-privilege and purpose-bound. Sensitive content **MUST** be minimized. Assurance services **MUST** preserve integrity, availability, chronology, and recoverability while preventing evidence or certificate possession from becoming Authority.

14. Verification method and metrics

Verify by artifact-schema inspection, traceability analysis, executable tests, independent reproduction, adversarial review, and decision-record inspection. Track claim coverage, freshness, reproduction rate, calibration error, escaped defects, invalidation latency, status-propagation latency, exception age, and assurance burden.

15. Traceability

- Book I/II/III/IV: Book I Decisions 1-7, 24-29, 38-43, 47-51, 56, 58; Book II Chapters 3-5, 18-21, 29, 35; Book III Chapters 5, 6, 8; Book IV CMP-01-03, CMP-17-21
- Book X: Assurance Case, Certification, Claim, Confidence, Evidence Object, Reality Boundary, Verification, and related canonical terms.
- Book IX: final contract mappings and the single governed certification-status extension are recorded in ``planning/BOOK_IX_RECONCILIATION_REGISTER.md``.

16. Examples and anti-patterns

Example: A release certificate cites exact build digests, claim results, reproduction, current authority-path tests, rollback rehearsal, and a bounded observation window.

Anti-pattern: A dashboard is labeled “green,” so a reviewer signs an indefinite certificate without examining data lineage, minority failures, stale inputs, authority paths, or revocation triggers.

17. Review findings, Owner Review, and completion

Constitutional fidelity: PASS. Architecture fidelity: PASS. Enforceability and testability: PASS. No Owner Review item. Chapter status: Final.